

**INTEGRASI KEAMANAN INFORMASI PADA SISTEM LOST AND
FOUND IPB UNIVERSITY**



Disusun oleh:

Nisa Amelia

G6401231022

Rahma Dhana

G6401231023

Kasyifa Naila

G6401231139

**PROGRAM SARJANA ILMU KOMPUTER
SEKOLAH SAINS DATA MATEMATIKA DAN INFORMATIKA
IPB UNIVERSITY
BOGOR
2026**

BAB 1: PENDAHULUAN

1.1 Latar Belakang

Sistem Lost and Found merupakan salah satu layanan penting di lingkungan kampus yang berfungsi membantu civitas akademika dalam melaporkan, mencari, dan mengklaim barang yang hilang atau ditemukan. Di IPB University, pengelolaan barang hilang masih seringkali dilakukan secara manual atau melalui kanal komunikasi informal, seperti grup percakapan dan papan pengumuman, yang rentan terhadap penyalahgunaan informasi maupun kurangnya privasi pelapor.

Seiring meningkatnya digitalisasi layanan kampus, dibutuhkan sebuah sistem informasi berbasis web yang terstruktur, aman, dan dapat diandalkan untuk menangani proses ini secara formal. Namun, digitalisasi juga membawa tantangan baru di bidang keamanan informasi. Sistem yang menyimpan data sensitif seperti identitas mahasiswa, informasi kontak, dan foto barang memerlukan perlindungan yang memadai agar tidak terjadi kebocoran data, manipulasi informasi, atau akses tidak sah.

Laporan teknis ini merupakan dokumentasi tahap pertama perancangan keamanan Sistem Lost and Found IPB University, yang mencakup analisis risiko keamanan (threat modeling), perancangan arsitektur keamanan, serta spesifikasi teknis protokol enkripsi yang digunakan untuk melindungi data sensitif dalam sistem.

1.2 Rumusan Masalah

Berdasarkan latar belakang yang telah diuraikan, rumusan masalah dalam proyek ini adalah:

- Bagaimana cara merancang sistem Lost and Found IPB University yang aman dari ancaman siber seperti session hijacking, dan pencurian data?
- Mekanisme enkripsi apa yang paling sesuai untuk melindungi data sensitif pengguna yang tersimpan di basis data (data at rest)?
- Bagaimana merancang protokol manajemen kunci kriptografi yang aman untuk mencegah kebocoran kunci enkripsi?
- Bagaimana mengintegrasikan lapisan keamanan (autentikasi, otorisasi, validasi input, enkripsi) ke dalam alur logika sistem secara kohesif?

1.3 Tujuan

Tujuan dari penyusunan laporan teknis tahap pertama ini adalah:

1. Mengidentifikasi aset data sensitif pada Sistem Lost and Found IPB University dan memetakan potensi ancaman keamanannya.
2. Merancang arsitektur keamanan sistem yang mencakup mekanisme autentikasi, perlindungan data, dan keamanan basis data.
3. Menentukan dan memjustifikasi pemilihan mode operasi enkripsi (AES-GCM) sebagai mekanisme perlindungan data sensitif.
4. Merancang protokol manajemen kunci (Key Management Protocol) yang aman.
5. Menyusun flowchart alur logika keamanan sistem sebagai dasar implementasi pada tahap berikutnya.

1.4 Ruang Lingkup

Laporan ini mencakup perancangan keamanan untuk komponen-komponen berikut dalam Sistem Lost and Found IPB University:

- Sistem autentikasi dan manajemen sesi pengguna (mahasiswa dan admin civitas IPB).
- Mekanisme perlindungan data pengguna yang tersimpan di basis data, meliputi data akun, data barang hilang, foto barang, dan riwayat tiket.
- Protokol enkripsi menggunakan AES-GCM untuk data at rest dan komunikasi data.
- Arsitektur manajemen kunci kriptografi menggunakan Key Vault/HSM.

Laporan ini tidak mencakup implementasi kode program secara detail (yang akan dibahas pada tahap berikutnya) maupun aspek keamanan jaringan di luar cakupan aplikasi.

1.5 Analisis Sistem yang Ada (Existing System Analysis)

Saat ini, pengelolaan barang hilang di lingkungan kampus IPB University umumnya dilakukan melalui:

- Grup pesan instan (WhatsApp) yang bersifat informal dan tidak terstruktur.
- Story Instagram IPB Hilang,
- Pelaporan langsung ke petugas keamanan atau administrasi tanpa sistem pencatatan yang baku.

Kelemahan utama sistem yang ada saat ini antara lain: tidak ada verifikasi identitas pelapor, data pribadi pelapor terekspos secara publik, tidak ada mekanisme pelacakan status barang yang transparan, rentan terhadap klaim palsu, dan tidak ada audit trail untuk pertanggungjawaban. Sistem baru yang dirancang bertujuan untuk mengatasi seluruh kelemahan ini dengan mengintegrasikan lapisan keamanan informasi yang komprehensif.

BAB 2: TINJAUAN PUSTAKA

2.1 Keamanan Informasi

Keamanan informasi (information security) adalah praktik melindungi informasi dari akses, penggunaan, pengungkapan, gangguan, modifikasi, atau penghancuran yang tidak sah. Keamanan informasi berlandaskan pada tiga prinsip utama yang dikenal sebagai CIA Triad:

- Confidentiality (Kerahasiaan): Menjamin bahwa informasi hanya dapat diakses oleh pihak yang berwenang.
- Integrity (Integritas): Menjamin bahwa informasi akurat, lengkap, dan tidak dimodifikasi secara tidak sah.
- Availability (Ketersediaan): Menjamin bahwa informasi dapat diakses oleh pihak yang berwenang kapan pun dibutuhkan.

2.2 Kriptografi Simetrik

Kriptografi simetrik adalah metode enkripsi di mana kunci yang sama digunakan untuk proses enkripsi maupun dekripsi. Algoritma AES (Advanced Encryption Standard) merupakan standar kriptografi simetrik yang paling banyak digunakan saat ini.

AES bekerja sebagai sandi blok (block cipher) yang memproses data dalam blok 128-bit dengan panjang kunci 128, 192, atau 256 bit. Dalam aplikasi nyata, AES dikombinasikan dengan mode operasi tertentu untuk menangani data yang lebih panjang dari satu blok.

2.3 Mode Operasi AES

Terdapat beberapa mode operasi AES yang umum digunakan, masing-masing dengan karakteristik keamanan yang berbeda:

Mode	Jenis	Confidentiality	Integrity Check	Authentication	Performance	Standar Modern
AES-GCM	AEAD (Authenticated and Encrypted)	Ada	Ada (Authentication Tag)	Ada	Cepat, dapat paralel	Digunakan pada TLS/HTTPS
AES-CBC	Block Cipher Mode	Ada	Tidak ada	Perlu tambahan (HMAC)	Lebih lambat (serial)	Mulai ditinggalkan
AES-CTR	Stream Cipher Mode	Ada	Tidak ada	Tidak ada	Sangat cepat	Jarang untuk web security

AES-GCM (Galois/Counter Mode) dipilih sebagai mode operasi dalam sistem ini karena menyediakan AEAD (Authenticated Encryption with Associated Data), yang menggabungkan enkripsi data dan verifikasi integritas dalam satu mekanisme yang efisien. Mode ini merupakan standar modern yang digunakan pada protokol TLS/HTTPS.

2.4 Manajemen Kunci Kriptografi

Keamanan sistem kriptografi sangat bergantung pada keamanan kunci enkripsi yang digunakan. Manajemen kunci (key management) mencakup proses pembangkitan, penyimpanan, distribusi, rotasi, dan penghapusan kunci kriptografi secara aman.

- **Key Vault / HSM (Hardware Security Module):** Perangkat atau layanan khusus untuk menyimpan kunci enkripsi secara terisolasi dan aman dari akses langsung.
- **Key Rotation:** Praktik mengganti kunci enkripsi secara berkala untuk membatasi dampak jika terjadi kebocoran kunci.
- **Access Control:** Mekanisme pembatasan akses ke kunci kriptografi hanya untuk entitas yang berwenang.

2.5 Autentikasi dan Manajemen Sesi

Autentikasi adalah proses verifikasi identitas pengguna sebelum memberikan akses ke sistem. Dalam konteks keamanan web, beberapa mekanisme yang relevan meliputi:

- Password Hashing: Proses mengubah password plain-text menjadi hash yang tidak dapat di-reverse, menggunakan algoritma seperti bcrypt atau Argon2.
- Session Management: Mekanisme pengelolaan status login pengguna menggunakan session token yang unik dan memiliki waktu kadaluarsa.
- Input Validation: Proses verifikasi data yang diinput pengguna untuk mencegah serangan seperti SQL Injection dan Cross-Site Scripting (XSS).

2.6 Threat Modeling

Threat modeling adalah proses terstruktur untuk mengidentifikasi, menilai, dan memprioritaskan ancaman keamanan terhadap sebuah sistem. Metodologi STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) sering digunakan sebagai kerangka kerja dalam threat modeling.

Hasil dari threat modeling digunakan untuk menginformasikan keputusan desain keamanan dan menentukan kontrol keamanan yang perlu diimplementasikan untuk memitigasi ancaman yang teridentifikasi.

BAB 3: METODOLOGI DAN PERANCANGAN KEAMANAN

3.1 Deskripsi Sistem Target

Sistem target adalah aplikasi web Lost and Found IPB University yang dirancang untuk memfasilitasi pelaporan dan pencarian barang hilang di lingkungan kampus IPB University. Sistem ini melibatkan dua kategori pengguna utama:

- Mahasiswa: Pengguna yang dapat melaporkan barang hilang atau temuan dengan membuat tiket laporan, melampirkan foto barang, dan melacak status tiket yang dibuat.
- Admin (Civitas IPB): Pengguna administrator yang mengelola database tiket, memverifikasi laporan, memperbarui status barang, dan menjadi penghubung antara pelapor kehilangan dan penemuan barang.

Fitur utama sistem mencakup manajemen akun pengguna, pembuatan dan pengelolaan tiket laporan barang hilang/ditemukan, sistem notifikasi, dan dashboard admin.

3.2 Identifikasi Aset Data

Identifikasi aset data dilakukan untuk menentukan data apa saja yang perlu dilindungi beserta tingkat sensitivitasnya. Berikut adalah aset data yang teridentifikasi dalam sistem:

No	Aset Data	Kategori	Tingkat Sensitivitas	Risiko jika Bocor
1	Data akun (username, password, email)	Data Pengguna	Sangat Tinggi	Akun dapat diambil alih, identitas pengguna terekspos
2	Data barang hilang (deskripsi, lokasi, waktu)	Data Laporan	Tinggi	Privasi pelapor terekspos, potensi klaim palsu
3	Foto barang	Data Media	Sedang	Bukti visual dapat disalahgunakan

No	Aset Data	Kategori	Tingkat Sensitivitas	Risiko jika Bocor
4	Riwayat laporan/tiket	Data Riwayat	Tinggi	Pola aktivitas pengguna terekspos
5	Informasi kontak pelapor	Data Pengguna	Sangat Tinggi	Penyalahgunaan data pribadi, potensi penipuan
6	Status dan histori tiket	Data Operasional	Sedang	Manipulasi status oleh pihak tidak berwenang

3.3 Analisis Risiko Keamanan (Threat Modeling)

Berdasarkan identifikasi aset data dan analisis sistem, tiga ancaman keamanan utama yang teridentifikasi pada Sistem Lost and Found IPB University adalah sebagai berikut:

3.3.1 Session Hijacking

Deskripsi: Serangan dengan mengambil alih session login pengguna sehingga penyerang dapat mengakses sistem tanpa mengetahui password pengguna yang sah. Penyerang biasanya mencuri session token melalui Cross-Site Scripting (XSS), packet sniffing pada jaringan tidak terenkripsi, atau dengan mengeksploitasi kelemahan implementasi session management.

Komponen yang terancam: Session login, data akun pengguna, dan riwayat tiket.

- Vektor serangan: XSS injection pada form input, man-in-the-middle attack pada jaringan publik.
- Dampak: Akses tidak sah ke akun pengguna, potensi modifikasi atau pencurian data laporan.
- Mitigasi: Implementasi HTTPS (TLS), penggunaan flag HttpOnly dan Secure pada cookie session, validasi IP dan User-Agent pada session, serta session timeout otomatis.

3.3.2 Pencurian Data

Deskripsi: Akses tidak sah ke basis data sistem yang dapat menyebabkan data pengguna, seperti data akun, informasi kontak, foto barang, dan riwayat laporan, dicuri atau disalahgunakan. Serangan ini dapat terjadi melalui SQL Injection, eksploitasi kelemahan konfigurasi database, atau insider threat.

Komponen yang terancam: Database sistem secara keseluruhan.

- Vektor serangan: SQL Injection melalui input yang tidak divalidasi, akses langsung ke database dengan kredensial yang lemah atau bocor.
- Dampak: Kebocoran data pribadi seluruh pengguna, potensi pelanggaran peraturan perlindungan data pribadi.
- Mitigasi: Penggunaan Prepared Statement atau ORM untuk mencegah SQL Injection, enkripsi data sensitif menggunakan AES-GCM sebelum disimpan di database, penerapan prinsip least privilege pada akun database, serta audit log akses database.

Ancaman	Komponen Terancam	Probabilitas	Dampak	Level Risiko	Prioritas Mitigasi
Session Hijacking	Session Login	Sedang	Tinggi	Tinggi	Prioritas 2
Pencurian Data (SQL Injection)	Database Sistem	Sedang	Sangat Tinggi	Sangat Tinggi	Prioritas 1

3.4 Arsitektur Keamanan Sistem

Berdasarkan hasil threat modeling, arsitektur keamanan sistem dirancang dengan tiga komponen utama:

3.4.1 Authentication (Autentikasi Pengguna)

Sistem autentikasi diimplementasikan dengan mekanisme login berbasis username dan password. Password pengguna tidak pernah disimpan dalam bentuk *plain text*; password

di-hash menggunakan algoritma hashing yang kuat sebelum disimpan ke basis data. Sistem juga menggunakan *session management* untuk menjaga status login pengguna selama sesi aktif.

- **Penyimpanan password:** Hashing menggunakan bcrypt dengan *salt* acak.
- **Session management:** Token sesi unik yang diregenerasi setelah login, dengan waktu kedaluwarsa yang telah ditentukan.

3.4.2 Data Protection (Perlindungan Data)

Data sensitif pengguna dienkripsi menggunakan algoritma AES-GCM sebelum disimpan ke basis data. Validasi input diterapkan pada seluruh formulir untuk mencegah data berbahaya masuk ke sistem. Komunikasi antara klien dan server menggunakan HTTPS (TLS) untuk melindungi data selama proses transmisi.

- **Enkripsi data saat penyimpanan (*data at rest*):** AES-GCM digunakan untuk melindungi data identitas pelapor, informasi kontak, dan deskripsi barang.
- **Enkripsi data saat transmisi (*data in transit*):** HTTPS/TLS digunakan untuk seluruh komunikasi antara klien dan server.
- **Validasi input:** Seluruh input pengguna disanitasi dan divalidasi sebelum diproses oleh sistem.

3.4.3 Database Security (Keamanan Basis Data)

Keamanan basis data diterapkan untuk melindungi data dari manipulasi dan akses yang tidak sah. Seluruh query basis data menggunakan *Prepared Statement* atau ORM (*Object-Relational Mapping*) untuk mencegah serangan SQL Injection. Validasi input juga dilakukan sebelum data disimpan ke basis data.

- **Pencegahan SQL Injection:** Penggunaan *Prepared Statement* atau ORM secara konsisten pada seluruh operasi basis data.
- **Prinsip *least privilege*:** Akun basis data yang digunakan aplikasi hanya diberikan hak akses minimum yang diperlukan.
- **Audit trail:** Seluruh aktivitas baca dan tulis pada data sensitif dicatat untuk keperluan pemantauan dan audit keamanan.

3.5 Flowchart Alur Logika Keamanan Sistem

Alur logika keamanan sistem menggambarkan tahapan keamanan yang diterapkan pada setiap interaksi pengguna dengan sistem, mulai dari proses login hingga penyimpanan data tiket laporan. Berikut merupakan deskripsi alur keamanan sistem secara tekstual.

Tahap 1: Autentikasi (*Authentication*)

Pengguna membuka aplikasi dan memasukkan *username* serta *password*. Sistem memvalidasi kredensial dengan mencocokkan hash *password* yang dimasukkan pengguna dengan hash yang tersimpan pada basis data. Apabila kredensial valid, proses login berhasil dan sesi pengguna dimulai. Sebaliknya, jika kredensial tidak valid, sistem akan menampilkan pesan kesalahan dan mencatat percobaan login yang gagal.

Tahap 2: Otorisasi (*Authorization*)

Setelah proses login berhasil, sistem memeriksa peran (*role*) pengguna. Pengguna dengan peran mahasiswa dapat membuat tiket laporan barang hilang atau ditemukan serta melacak status laporan yang telah dibuat. Sementara itu, pengguna dengan peran admin memiliki hak akses tambahan untuk melakukan verifikasi tiket dan mengelola sistem.

Tahap 3: Validasi Input

Ketika pengguna membuat tiket laporan barang, seluruh data yang dimasukkan, seperti deskripsi barang, lokasi, dan informasi kontak, akan melalui proses validasi dan sanitasi sebelum diproses oleh sistem. Validasi dilakukan dengan memeriksa format data, panjang karakter, serta karakter yang diperbolehkan guna mencegah berbagai bentuk serangan *injection*.

Tahap 4: Enkripsi Data (AES-GCM)

Setelah data dinyatakan valid, informasi sensitif yang terdapat pada tiket laporan akan dienkripsi menggunakan algoritma AES-GCM sebelum disimpan ke basis data. Pada proses ini, *Authentication Tag* juga dihasilkan untuk memastikan integritas data dan mendeteksi adanya perubahan yang tidak sah.

Tahap 5: Penyimpanan Terenkripsi

Data yang telah dienkripsi disimpan ke dalam basis data dalam bentuk *ciphertext*. Kunci enkripsi yang digunakan untuk proses enkripsi dan dekripsi disimpan secara terpisah dan tidak ditempatkan pada basis data yang sama dengan data terenkripsi.

Tahap 6: Pemrosesan Admin dan Notifikasi

Admin melakukan verifikasi terhadap tiket laporan yang masuk ke dalam sistem. Berdasarkan hasil verifikasi, status barang dapat diperbarui, misalnya menjadi ditemukan atau belum ditemukan. Jika barang berhasil ditemukan, sistem akan mengirimkan notifikasi kepada pelapor terkait untuk memberikan informasi mengenai perkembangan laporan yang telah dibuat.

REFERENSI

- National Institute of Standards and Technology (NIST). (2001). Advanced Encryption Standard (AES). FIPS Publication 197.
- Dworkin, M. (2007). Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. NIST Special Publication 800-38D.
- OWASP Foundation. (2021). OWASP Top 10 Web Application Security Risks. <https://owasp.org/www-project-top-ten/>
- OWASP Foundation. (2023). Authentication Cheat Sheet. OWASP Cheat Sheet Series.
- Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley.
- Ferguson, N., Schneier, B., & Kohno, T. (2010). Cryptography Engineering: Design Principles and Practical Applications. Wiley.